IAM-06: User Lifecycle and Provisioning

> **Series:** IAM — IAM Administration | **Notebook:** 6 of 12 | **Created:** January 2026 | **Last Updated:** 10/12/2026

Automating User Management at Scale

Manual user management doesn't scale. This notebook covers user lifecycle automation including SCIM provisioning, JIT access, service accounts, token management, and inviting external users from other domains.

Table of Contents

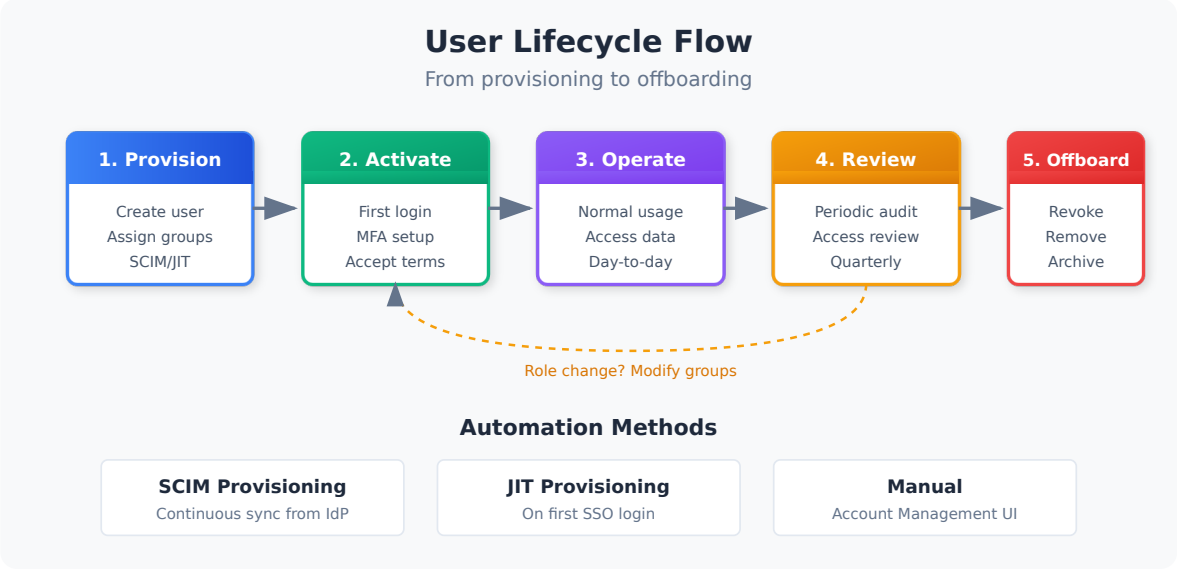
1. SCIM Provisioning
2. Just-in-Time Provisioning
3. User Onboarding Workflows
4. User Offboarding
5. Service Accounts and OAuth Clients
6. API Token Management
7. External User and Cross-Domain Access

Prerequisites

Requirement	Details
Dynatrace Environment	SaaS with Gen3 IAM enabled
Permissions	`account-user-management` for user/token management
IdP	Enterprise IdP (Okta, Azure AD, etc.) for SCIM

1. User Lifecycle Overview

Users have a lifecycle from creation to deactivation. Effective management requires automation at each stage.



Lifecycle Stages

Stage	Description	Automation
Provision	Create user identity	SCIM, JIT
Assign	Add to groups, grant access	SCIM group sync
Activate	First login, MFA setup	SSO integration
Operate	Normal access and usage	N/A
Review	Periodic access review	Audit queries
Modify	Change groups/access	SCIM update
Offboard	Remove access	SCIM delete, JIT expiry

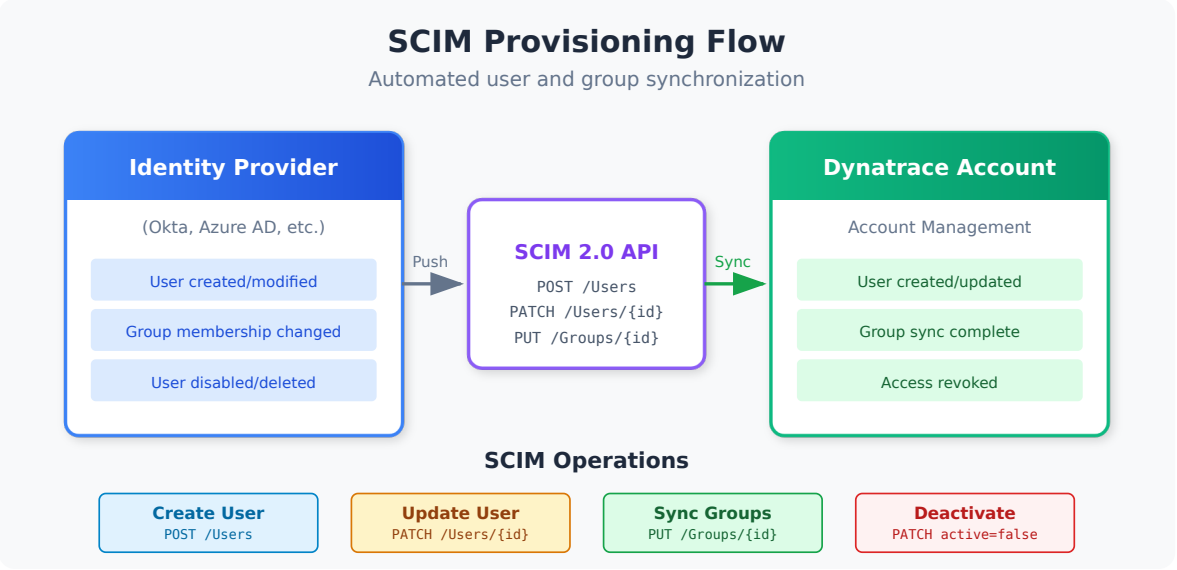
Manual vs Automated

Method	Pros	Cons	Scale
Manual	Full control	Slow, error-prone	< 50 users
SCIM	Automated sync	Setup complexity	50 - 10,000+ users
JIT	No pre-provisioning	Less control	Any size

2. SCIM Provisioning

SCIM (System for Cross-domain Identity Management) automatically syncs users and groups from your IdP to Dynatrace.

> **Breaking (SaaS 1.347 — staged tenant rollout from 09/16/2026):** `GET /Users` **pagination is now RFC-compliant.** Verbatim: *"The SCIM `GET /Users` endpoint now interprets `startIndex` as the absolute, 1-based index of the first result, per RFC 7644."*
>
> **A client that passed a page number silently reads the wrong window.** Under the old interpretation `startIndex=2` meant "the second page"; under RFC 7644 it means "start at record 2". The request still returns `200` with a well-formed body, so the failure surfaces as users that never sync rather than as an error — the same silent shape that makes provisioning bugs hard to attribute.
>
> If you drive SCIM through a commercial IdP connector (Entra ID, Okta), it is almost certainly already RFC-compliant and needs no change. **The population at risk is hand-rolled sync scripts**, which is exactly what a page-number loop looks like. Convert to `startIndex = (page - 1) * count + 1` and reconcile a full user list after the rollout reaches your tenant.



How SCIM Works

1. You configure SCIM in your IdP (Okta, Azure AD, etc.)
2. When users/groups change in IdP, SCIM syncs to Dynatrace
3. Users are automatically created, updated, or deactivated
4. Group memberships stay in sync

Supported IdPs

IdP	SCIM Support	Notes
Okta	Full	Native integration
Azure AD (Entra ID)	Full	Enterprise app provisioning
OneLogin	Full	Directory provisioning
PingFederate	Full	Provisioning connector
Google Workspace	Partial	Requires adapter

SCIM Configuration Steps

In Dynatrace:

1. Navigate to Account Management → Identity providers
2. Select your IdP configuration
3. Enable SCIM provisioning
4. Copy the SCIM endpoint URL and token

In Your IdP (Example: Okta):

1. Open your Dynatrace SAML application
2. Go to Provisioning tab
3. Configure SCIM connection:
   - SCIM connector base URL
   - API token (from Dynatrace)
4. Enable provisioning features:
   - Create Users
   - Update User Attributes
   - Deactivate Users
   - Push Groups

SCIM Attributes Synced

Attribute	Source	Dynatrace Field
userName	IdP email	Email (login)
givenName	IdP first name	First name
familyName	IdP last name	Last name
active	IdP status	Account status

Attribute	Source	Dynatrace Field
groups	IdP group membership	Group membership

Best Practices

- **Test in sandbox** before production
- **Map groups explicitly** - don't auto-create
- **Use consistent naming** between IdP and Dynatrace
- **Monitor sync status** for failures

> **Sources:** What's new in Dynatrace SaaS 1.347 (DT docs) — the SCIM `GET /Users` `startIndex` change quoted above.

3. Just-in-Time Provisioning

JIT provisioning creates users automatically on first login via SSO.

How JIT Works

1. User authenticates via SAML SSO
2. If user doesn't exist, Dynatrace creates them
3. Group memberships assigned based on SAML assertion
4. User accesses Dynatrace immediately

JIT vs SCIM

Aspect	JIT	SCIM
User created	On first login	Before login
Deactivation	Manual or session-based	Automatic sync
Group sync	At login only	Continuous
Setup	Simple	More complex
Control	Less	More

Configuring JIT

1. Navigate to Account Management → Identity providers

2. Select your SAML configuration
3. Enable "Auto-provision users on login"
4. Configure default group for new users
5. Map SAML groups to Dynatrace groups

JIT Group Mapping

SAML assertion includes groups, which are mapped to Dynatrace groups:

SAML Group	Dynatrace Group
`IT-Dynatrace-Admins`	`dt-platform-admins`
`App-Checkout-Team`	`dt-checkout-editors`
`All-Employees`	`dt-all-viewers`

JIT Considerations

Pro	Con
Simple setup	User created only after login
No pre-provisioning needed	Group sync only at login
Self-service access	Harder to audit who has access

4. User Onboarding Workflows

Standard Onboarding Process

Step	Action	Owner
1	Add user to IdP group	HR/IT
2	SCIM syncs user to Dynatrace	Automatic
3	User receives welcome email	IT
4	User logs in via SSO	User
5	User completes MFA setup	User
6	Access verified	User/Manager

New Employee Checklist

```
☐ Employee added to corporate directory
☐ Employee assigned to appropriate IdP groups
☐ SCIM sync verified (user appears in Dynatrace)
☐ Employee logs in successfully
☐ Employee completes MFA enrollment
☐ Employee confirms access to required data
```

Role Change Process

When users change roles:

1. Manager requests access change
2. IAM admin approves
3. Update IdP group membership
4. SCIM syncs changes
5. User has new access on next login

Temporary Access

For contractors or short-term access:

Method	Duration	Automation
IdP time-limited group	Days to months	IdP policy
Manual group removal	Any	Calendar reminder
OAuth client expiry	Hours to days	Token config

5. User Offboarding

Proper offboarding is critical for security.

Offboarding Triggers

Trigger	Response	Timing
Termination	Full revocation	Immediate
Resignation	Full revocation	Last day
Role change	Partial revocation	At change

Trigger	Response	Timing
Contract end	Full revocation	End date

Automated Offboarding (SCIM)

1. User disabled/removed in IdP
2. SCIM syncs deactivation to Dynatrace
3. User cannot login
4. Existing sessions invalidated

Manual Offboarding Checklist

```
☐ Remove from all Dynatrace groups
☐ Revoke any API tokens created by user
☐ Deactivate OAuth clients owned by user
☐ Transfer ownership of dashboards/notebooks
☐ Review audit log for recent activity
☐ Document offboarding completion
```

Token Revocation on Offboarding

Critical: User-created tokens remain active until explicitly revoked.

Query to find user's tokens:

```
Account Management → API tokens
Filter by: Created by [user email]
Action: Revoke all tokens
```

Verification

After offboarding, verify:

- [ ] User cannot login via SSO
- [ ] User not in any groups
- [ ] User's tokens are revoked
- [ ] No active OAuth clients

6. Service Accounts and OAuth Clients

Non-human identities require special handling.

Service Accounts vs OAuth Clients

Type	Use Case	Authentication
Service Account	Automation, scripts	API token
OAuth Client	Apps, integrations	OAuth 2.0

Creating OAuth Clients

1. Account Management → OAuth clients
2. Create new client
3. Configure:
   - Name and description
   - Grant type (client credentials)
   - Scopes (permissions)
   - Token lifetime
4. Save client ID and secret securely

OAuth Client Best Practices

Practice	Rationale
One client per application	Isolation, easy revocation
Minimum scopes	Least privilege
Short token lifetime	Reduce exposure
Rotate secrets regularly	Security hygiene
Document ownership	Accountability

OAuth Scopes

Common scopes for automation:

Scope	Grants
`storage:logs:read`	Read logs
`storage:metrics:read`	Read metrics
`settings:objects:read`	Read settings
`settings:objects:write`	Modify settings
`document:documents:read`	Read dashboards

Service Account Lifecycle

Event	Action
Create	Document owner, purpose, expiry
Review (quarterly)	Verify still needed
Owner change	Update documentation
Decommission	Revoke client, archive docs

7. API Token Management

API tokens provide access for scripts, tools, and legacy integrations.

Token Types

Type	Scope	Use Case
Personal	User's permissions	User automation
Service	Specific scopes	Application integration

Token Scopes Reference

Scope	Permission
`logs.read`	Read log data
`metrics.read`	Read metrics
`entities.read`	Read entity data
`settings.read`	Read settings
`settings.write`	Modify settings
`problems.read`	Read problems
`events.ingest`	Send events

Token Best Practices

Practice	Implementation
Minimum scopes	Only grant what's needed

Practice	Implementation
Descriptive names	`cicd-pipeline-metrics-reader`
Expiration dates	Set reasonable expiry
Rotation schedule	Rotate every 90 days
Secure storage	Use secrets manager
No sharing	One token per use case

Token Rotation Process

1. Create new token with same scopes
2. Update applications with new token
3. Verify applications work
4. Revoke old token
5. Document rotation

> **Deprecation — Dynatrace API 1.348 (pre-release; staged rollout planned from 09/22/2026).** The API 1.348 changelog (DT docs) marks the whole `/apiTokens` endpoint family deprecated — *"The following endpoints are deprecated"*: `GET` / `POST /apiTokens`, `POST /apiTokens/lookup`, and `GET` / `PUT` / `DELETE /apiTokens/{id}`. That changelog names no successor. Deprecated endpoints keep working during the deprecation period, so the rotation steps above remain the working path; re-check the changelog when 1.348 reaches GA before building new rotation automation on these endpoints.
>
> **Phase 3 environments cannot run step 1.** Once an environment opts into **Phase 3** of the upgrade to Latest Dynatrace, *"classic API token creation is disabled; all new integrations must use platform tokens"* (Best practices for upgrading App Observability API endpoints (DT docs)). "Create new token with same scopes" then fails. Check your environment's upgrade phase before you rotate. In a Phase 3 environment, move the consumer onto a platform token or an OAuth client instead of minting a replacement classic token.

Tenant Token Rotation — a Different Object

Everything above concerns **API tokens**. The **tenant token** is a different credential: it is what OneAgents and ActiveGates use to authenticate to the cluster. It is not created, scoped, or revoked through the API-token surface, and rotating it affects **the monitored fleet**, not a script or a pipeline. Nothing in the rotation process above applies to it.

	API token	Tenant token
Used by	Scripts, pipelines, integrations	OneAgents and ActiveGates

	API token	Tenant token
Created / scoped by you	Yes — you choose the scopes	No — issued by the environment
Rotation blast radius	The consumers you updated	Every agent reporting to the environment
"Done" means	Your applications still work	Every agent has picked up the new token

Forthcoming / rolling out (API 1.344). Dynatrace API 1.344 (published 07/15/2026, rollout from 07/29/2026) adds `GET /tenantTokenRotation/status` to Environment API v2 — verify it has reached your tenant before scripting against it.

The point of the endpoint is that it makes a rotation **auditable rather than assumed**. Rotating a tenant token is a two-state affair: the new token is issued, and then agents pick it up on their own schedule. Without a status surface you retire the old token on faith. With it you can confirm the fleet has converged *before* treating the old token as retired — which is exactly the evidence an auditor asks for, and the check that prevents a stranded agent from going dark.

Until it reaches your tenant, the pre-1.344 working path is unchanged: verify rotation from the deployment surface — check the Deployment Status page and confirm agents reconnect and keep reporting after the rotation, rather than inferring success from the absence of complaints. Keep that check even once the endpoint is available; it is the one that tells you an agent is *monitoring*, not merely *authenticated*.

Monitoring Token Usage

Use audit logs to track token activity.

```
// Track API token usage patterns
// Data object corrected 08/12/2026. The Dynatrace audit trail is NOT in `logs`: this
cell used
// `fetch logs | filter matchesPhrase(log.source, "audit")`, and no log.source on a
Grail tenant
// contains "audit" — the filter matched nothing, silently, forever. Platform audit
records live in
// `dt.system.events` with `event.kind == "AUDIT_EVENT"` (265,000+ records over 7 days
here), and
// they are STRUCTURED, so the old `matchesPhrase(content, ...)` string-scraping is
replaced by real
// field predicates. Key fields: user.id, user.organization, event.type
(GET/POST/PUT/PATCH/DELETE/
// CREATE/LOGIN/app.opened), event.outcome (HTTP status or "success"),
authentication.type
// (OAUTH2/TOKEN/NONE), authentication.grant.type, resource (the API path),
origin.address,
// origin.type, request.source, dt.app.id, event.provider.
// Enumerate your own with:
//   fetch dt.system.events, from:-24h | filter event.kind == "AUDIT_EVENT" | limit 1
fetch dt.system.events, from:-7d
| filter event.kind == "AUDIT_EVENT"
| filter authentication.type == "TOKEN"
| summarize calls = count(), by:{user.id, event.provider}
| sort calls desc
| limit 25
```

```
// Token lifecycle: API and ActiveGate token creation, update and deletion
// Token events carry event.provider API_TOKEN / ACTIVE_GATE_TOKEN, and their resource
is the token ID —
// a contains(resource, "token") filter misses them and matches only /lookups/iam_tokens
uploads.
// Data object corrected 08/12/2026. The Dynatrace audit trail is NOT in `logs`: this
cell used
// `fetch logs | filter matchesPhrase(log.source, "audit")`, and no log.source on a
Grail tenant
// contains "audit" — the filter matched nothing, silently, forever. Platform audit
records live in
// `dt.system.events` with `event.kind == "AUDIT_EVENT"` (265,000+ records over 7 days
here), and
// they are STRUCTURED, so the old `matchesPhrase(content, ...)` string-scraping is
replaced by real
// field predicates. Key fields: user.id, user.organization, event.type
(GET/POST/PUT/PATCH/DELETE/
// CREATE/LOGIN/app.opened), event.outcome (HTTP status or "success"),
authentication.type
// (OAUTH2/TOKEN/NONE), authentication.grant.type, resource (the API path),
origin.address,
// origin.type, request.source, dt.app.id, event.provider.
// Enumerate your own with:
//   fetch dt.system.events, from:-24h | filter event.kind == "AUDIT_EVENT" | limit 1
fetch dt.system.events, from:-30d
| filter event.kind == "AUDIT_EVENT"
| filter in(event.provider, {"API_TOKEN", "ACTIVE_GATE_TOKEN"})
| fields timestamp, user.id, event.provider, event.type, resource, event.outcome
| sort timestamp desc
| limit 50
```

```
// Monitor OAuth client activity
// Data object corrected 08/12/2026. The Dynatrace audit trail is NOT in `logs`: this
cell used
// `fetch logs | filter matchesPhrase(log.source, "audit")`, and no log.source on a
Grail tenant
// contains "audit" — the filter matched nothing, silently, forever. Platform audit
records live in
// `dt.system.events` with `event.kind == "AUDIT_EVENT"` (265,000+ records over 7 days
here), and
// they are STRUCTURED, so the old `matchesPhrase(content, ...)` string-scraping is
replaced by real
// field predicates. Key fields: user.id, user.organization, event.type
(GET/POST/PUT/PATCH/DELETE/
// CREATE/LOGIN/app.opened), event.outcome (HTTP status or "success"),
authentication.type
// (OAUTH2/TOKEN/NONE), authentication.grant.type, resource (the API path),
origin.address,
// origin.type, request.source, dt.app.id, event.provider.
// Enumerate your own with:
//   fetch dt.system.events, from:-24h | filter event.kind == "AUDIT_EVENT" | limit 1
fetch dt.system.events, from:-7d
| filter event.kind == "AUDIT_EVENT"
| filter authentication.type == "OAUTH2"
| summarize calls = count(), by:{authentication.grant.type, request.source}
| sort calls desc
```

8. External User and Cross-Domain Access

Not all users come from your corporate directory. Consultants, partners, vendors, and Dynatrace support engineers may need access to your tenant. This section covers how to invite users from external domains and manage their access securely.

Inviting an External User

Account Management UI:

1. Navigate to **Account Management** → **Identity & access management** → **People**
2. Click **Invite user**
3. Enter the external user's email address (any domain — no allowlisting required)
4. The user receives an email invitation to create a Dynatrace account or log in with existing credentials
5. Once accepted, assign the user to the appropriate groups

> **Note:** The invitation is sent to the email address you enter. The external user does not need to be in your corporate directory or IdP. They create a local Dynatrace account with that email

> address.

How External Users Authenticate

Scenario	Auth Method	Notes
No SSO configured for their domain	Local Dynatrace account (email + password)	User creates account when accepting the invitation
Their domain is federated	SSO via their own IdP	Requires Account or Environment Federation configuration
Your IdP includes them as guest	SSO via your IdP	Common with Azure AD B2B guest users
SAML Federation configured	SSO via federated IdP	External domain must be added to your SAML federation

Assigning Permissions to External Users

External users can be assigned to any Dynatrace group — the same groups and policies that apply to internal users. Best practices:

Practice	Rationale
Create a dedicated group (e.g., `external-consultants`)	Isolate external access for easy audit and revocation
Apply least-privilege policies	External users should only see what they need
Use WHERE clauses to scope access	Restrict to specific environments, schemas, or data boundaries
Set time-bound access	Use IdP group expiration or calendar reminders for contractor end dates
Enforce MFA	Require multi-factor authentication for all external accounts

Example: Granting a Consultant Read-Only Access

1. **Create group:** `external-acme-consultants`
2. **Bind policy:** Read-only access scoped to the relevant environment

```
ALLOW environment:roles:viewer;
ALLOW settings:objects:read
  WHERE settings:schemaId startsWith "builtin:alerting";
ALLOW storage:logs:read
  WHERE storage:dt.security_context = "checkout-team";
```

3. **Invite user:** consultant@acme.com
4. **Add to group:** `external-acme-consultants`
5. **Set review date:** Contractor end date in your access review calendar

API Provisioning of External Users

The Account Management API supports programmatic user invitation:

Operation	API Endpoint	Method
Invite user	`/iam/v1/accounts/{accountUuid}/users`	POST
List users	`/iam/v1/accounts/{accountUuid}/users`	GET
Add user to group	`/iam/v1/accounts/{accountUuid}/groups/{groupUuid}/users`	POST
Remove user from group	`/iam/v1/accounts/{accountUuid}/groups/{groupUuid}/users/{userUuid}`	DELETE

Security Considerations

Consideration	Recommendation
No SCIM sync	External users without SSO cannot benefit from automatic provisioning or group sync — manage manually
Domain verification	Required for federated SSO configurations; not required for local account invitations
Token creation	External users with appropriate permissions can create API tokens — monitor via audit logs
Offboarding	External users must be explicitly removed; they are not deactivated by your corporate IdP offboarding flow
Regular access reviews	Review external user access quarterly (or more frequently for privileged access)
Fallback admin	Maintain at least one local admin account to prevent lockout during SSO or federation changes

External User Offboarding Checklist

```
☐ Remove from all Dynatrace groups
☐ Revoke any API tokens created by the external user
☐ Deactivate any OAuth clients they own
☐ Transfer ownership of shared dashboards/notebooks
☐ Verify user cannot login
☐ Document offboarding completion with date
```

Next Steps

With user lifecycle management in place, proceed to compliance:

Recommended Path

1. **IAM-07: Audit Logging and Compliance** - Monitor and report on access
2. **IAM-08: Multi-Environment IAM** - Scale across environments
3. **IAM-09: Troubleshooting Access Issues** - Debug problems

User Lifecycle Checklist

Before moving on, ensure you have:

- [ ] Chosen SCIM, JIT, or manual provisioning
- [ ] Configured IdP integration for provisioning
- [ ] Documented onboarding process
- [ ] Documented offboarding process
- [ ] Established token management policy
- [ ] Created service account inventory
- [ ] Defined process for inviting and managing external users

---

Summary

In this notebook, you learned:

- User lifecycle stages and automation options
- SCIM provisioning configuration
- Just-in-time provisioning via SSO
- User onboarding and offboarding workflows

- Service account and OAuth client management
- API token best practices and rotation
- How to invite external users from other domains and manage cross-domain access securely

---

References

- Manage Users, Groups, and Permissions
- SCIM Provisioning
- SAML Federation
- OAuth Clients
- API Tokens
- Dynatrace API 1.348 changelog (DT docs) — *"The following endpoints are deprecated"* (the `/apiTokens` family; pre-release)
- Best practices for upgrading App Observability API endpoints (DT docs) — *"For Phase 3 environments, classic API token creation is disabled; all new integrations must use platform tokens."*
- Account Management API

This notebook was AI-generated from community-submitted and publicly available sources. This notebook series is not officially supported by Dynatrace. Always verify information against official Dynatrace documentation.